

VICTORIA HEALTH GROUP

Healthcare Governance, Risk & Compliance (GRC) Executive Report

Portfolio Risk Assessment Simulation

Prepared by: Ambika Samanta

Role: GRC Analyst (Portfolio Simulation)

GitHub Repository: [Victoria Health Group – Healthcare GRC Assessment](#)

01. EXECUTIVE SUMMARY:

Assessment Scope:

Assess cybersecurity, compliance, operational, and third-party risks associated with the post-acquisition integration of Victoria Health Group. The assessment evaluates existing controls, identifies significant organizational risks, recommends remediation activities, and supports management in making informed risk-based decisions.

02. RISK REGISTER SUMMARY:

A comprehensive enterprise risk assessment identified five critical organizational risks following the integration of Victoria Health Group and its newly acquired hospitals. Each risk was evaluated using a 5x5 Likelihood-Impact Risk Matrix, considering inherent risk, existing controls, residual risk, business impact, risk ownership, and the selected treatment strategy.

Critical Risks Identified:

- Unpatched Medical IoT Devices
- Inconsistent Password Policies
- Absence of a Formal Incident Response Plan
- Shared Privileged Accounts Without Multi-Factor Authentication (MFA)
- Third-Party Vendor Security Assurance

The assessment determined that several existing controls were either ineffective or insufficient to reduce identified risks to an acceptable level. As a result, multiple risks remained at a Critical residual risk level and require management attention through planned remediation activities.

Key Outcome:

The Risk Register provides management with a prioritized view of organizational risks, assigned risk ownership, treatment strategies, and remediation priorities to support effective risk-based decision-making.

03. RISK APPETITE & ACCEPTANCE CRITERIA:

Victoria Health Group established enterprise risk appetite levels across six key risk categories to support consistent risk-based decision-making following the acquisition of three hospitals.

- Patient Safety:
Zero risk appetite. Any risk that could result in patient harm is unacceptable.
- Compliance:
Low risk appetite. High compliance risks require immediate treatment to maintain regulatory obligations.
- Operational:
Moderate risk appetite. Limited operational disruption may be accepted provided if patient safety is not affected.
- Financial:
Moderate risk appetite. Financial losses are acceptable only within approved organizational limits.
- Reputational:
Low risk appetite. Significant damage to patient and public trust is unacceptable.

- Cyber:
Low risk appetite. Critical cybersecurity risks require immediate remediation to protect patient information and essential healthcare services.

Key Outcome:

All identified risks exceeded one or more organizational risk acceptance criteria and require treatment before they can be considered acceptable.

04. CONTROL EFFECTIVENESS SUMMARY:

A review of administrative, technical, and physical security controls was conducted to evaluate the effectiveness of existing safeguards supporting Victoria Health Group's post-acquisition environment.

Key Control Gaps:

- Multi-Factor Authentication (MFA)
- Incident Response Planning
- Security Awareness Training
- Vendor Due Diligence

Several foundational controls, including network firewalls, password management, backup procedures, and physical security controls, were implemented but remained inconsistently applied or required further improvement to effectively reduce organizational risk.

Key Outcome:

Victoria Health Group demonstrates foundational security capabilities; however, additional control improvements are required to strengthen cybersecurity, support regulatory compliance, and reduce residual risk across the identified risk areas.

05. THIRD-PARTY VENDOR RISK SUMMARY:

A vendor risk assessment was conducted to evaluate the security and compliance posture of critical third-party service providers supporting Victoria Health Group.

Medicare Billing Co

- Processes Protected Health Information (PHI) and healthcare billing data.
- Residual Risk: Critical
- Significant assurance gaps were identified due to the absence of independent assurance evidence and limited contractual security assurance.
- Recommendation:
Require remediation and obtain assurance evidence before continuing the business relationship.

AWS Cloud Hosting

- Supports cloud infrastructure for healthcare applications and data storage.
- Residual Risk: Medium
- Independent assurance evidence and implemented security controls provide reasonable assurance regarding the vendor's security posture.
- Recommendation:
Accept the residual risk while continuing periodic security and compliance reviews.

Key Outcome:

The assessment identified varying levels of third-party risk and emphasized the importance of continuous vendor governance, independent assurance, and ongoing security monitoring.

06. EXECUTIVE RECOMMENDATIONS:

Objective

Reduce organizational risk by implementing prioritized remediation activities that strengthen security controls, improve governance, and align identified risks with Victoria Health Group's risk acceptance criteria.

30-Day Priorities:

Focus on immediate cybersecurity and compliance risk reduction.

- Implement Multi-Factor Authentication (MFA) for all privileged accounts.

Owner: IAM Team Lead

Related Risk: R-004

- Begin network segmentation for Medical IoT devices.

Owner: Network Team Lead

Related Risk: R-001

- Initiate vendor remediation by obtaining independent assurance evidence and updating contractual security requirements.

Owner: Vendor Risk Manager / Procurement Manager

Related Risk: R-005

60-Day Priorities:

Strengthen detection and response capabilities.

- Develop, approve, and test a formal Incident Response Plan.

Owner: Information Security Manager

Related Risk: R-003

- Standardize enterprise password policies across all acquired hospitals.

Owner: Head of IT Operations

Related Risk: R-002

- Deliver Security Awareness Training for employees handling sensitive information.

Owner: HR & Information Security Team

90-Day Priorities:

Strengthen governance and validate remediation effectiveness.

- Conduct backup restoration testing and validate Recovery Time Objective (RTO) and Recovery Point Objective (RPO).

Owner: Infrastructure Team

- Perform a follow-up enterprise risk assessment to measure remediation effectiveness.

Owner: GRC Team

- Review vendor security posture and verify that identified assurance gaps have been addressed.

Owner: Vendor Risk Manager

Expected Outcome:

Successful completion of the remediation roadmap is expected to reduce organizational risk, improve control effectiveness, strengthen governance, and align organizational risks with Victoria Health Group's risk acceptance criteria while enhancing cybersecurity resilience and regulatory compliance.

07. PROJECT REPOSITORY:

The complete project, including the Healthcare GRC Assessment workbook, supporting documentation, and project files, is available on GitHub.

GitHub Repository:

<https://github.com/ambika9123github/grc-victoria-health-implementation>
